Merge Status Code

PROM06 REM-TC02: remediation validation #85

Open abdulwaheed384 wants to merge 2 commits into `main` from `rem-tc02`

Conversation 3 Commits 2 Checks 1 Files changed 1 +14

Reviewers

No reviews

Still in progress? Convert to draft

Assignees

No one—assign yourself

Labels

None yet

Projects

None yet

Milestone

No milestone

Development

Successfully merging this pull request may close these issues.

None yet

1 participant

abdulwaheed384 commented 3 hours ago Owner

PROM06 remediation validation (DCR) for TC02. Applies the AI-recommended fix from TC02 run 38404584887 F-001 to the original fixture branch indep-tc02. Where the AI suggested a placeholder source range, the RFC 5737 documentation address 203.0.113.10/32 is used. Research only: do not merge, do not apply.

🤖 Generated with Claude Code

https://claude.ai/code/session_019GGG1f33Kz2g4dpPAJoY44

Generated by Claude Code

abdulwaheed384 and others added 2 commits 4 hours ago

`PROM06 Evidences Collection TC02` ··· Unverified `3eda6f7`

`PROM06 remediation validation: apply AI-recommended fix for TC02` ··· Unverified `386c2ac`

github-actions Bot commented 3 hours ago

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 7 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.

github-actions Bot commented 3 hours ago

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_CLEAN
Findings: 0

No findings were reported.

github-actions Bot commented 3 hours ago

AI Security Review

Experiment condition: INDEPENDENT
Automated operational score: 70/100 — MEDIUM — APPROVE_WITH_COMMENTS
This tool is for demonstration purposes only.

Summary

The AI reviewer reported 1 confirmed actionable finding(s).

Findings

- **HIGH · SECURITY_VULNERABILITY · SSH allow rule references a documentation-reserved (RFC 5737 TEST-NET-3) source address**
  - Category rationale: The AllowSSH rule permits inbound TCP/22 from 203.0.113.10/32. RFC 5737 designates the 203.0.113.0/24 block (TEST-NET-3) exclusively for documentation and example use; it is not a routable internet address and cannot be a legitimate operator source IP. This means the rule either grants access to an unintended or placeholder source, or the intended authorised source IP was never recorded — in either case the effective access control for SSH is not correctly specified. Additionally, the inline comment 'TC02: Deliberately unrestricted SSH access' does not match the scoped source prefix, suggesting the rule intent and its implementation may be misaligned.
  - Evidence: azurerm_network_security_group.nsg, security_rule 'AllowSSH': priority=300, direction=Inbound, access=Allow, protocol=Tcp, destination_port_range=22, source_address_prefix='203.0.113.10/32'. RFC 5737 documents 203.0.113.0/24 as TEST-NET-3, reserved for documentation use only.
  - Analysis: The NSG security_rule 'AllowSSH' allows inbound TCP port 22 from source_address_prefix '203.0.113.10/32'. The 203.0.113.0/24 range is reserved by RFC 5737 as TEST-NET-3 for use in documentation and examples; it is never assigned to real hosts and is not routable on the public internet or within Azure. A rule targeting this address either (a) was written with a placeholder IP that was never replaced with a real management address, leaving SSH potentially unprotected by this rule while another path may exist, or (b) reflects a misconfiguration where the intended authorised IP was not captured. The inline comment 'TC02: Deliberately unrestricted SSH access' further suggests the rule intent may differ from its current implementation.
  - Impact: If the placeholder IP was never replaced with a real authorised management address, SSH access control relies solely on Azure's default deny (and the DenyAllInbound rule at priority 4096) rather than on an intentional allowlist. If the comment 'TC02: Deliberately unrestricted SSH access' reflects a broader intent that was partially implemented, the actual exposure may differ from what the rule expresses. In either case the NSG does not demonstrably enforce access from a real, authorised source for SSH.
  - Recommendation: Replace source_address_prefix '203.0.113.10/32' with the actual authorised management IP or CIDR range for the operator or bastion host permitted to reach SSH. If SSH access is not required for this research workload, remove the AllowSSH rule entirely. Reconcile the inline comment to accurately describe the intended access control posture.

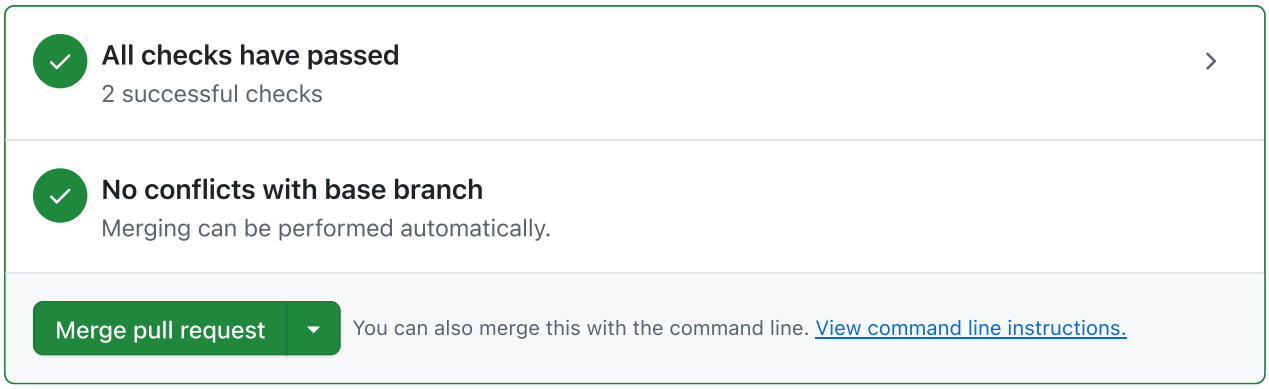
Recommendation

Review and remediate the confirmed findings above.

abdulwaheed384 added a commit that referenced this pull request 2 hours ago

`PROM06: step 3 metrics, timing and remediation-validation evidence` Unverified `8d7166b`

...



Still in progress? Convert to draft